Automated VAPT Assessment & Triage Report

1. Engagement Scope & Rules of Engagement

Authorized Target Scope: 127.0.0.1:3000

Execution Timestamp: 2026-11-08 21:07:56

Rules of Engagement: Non-destructive local sandbox testing restricted strictly to authorized loopback assets.

2. Tools & Ingestion Sources

- Nmap Network Mapper: Live Subprocess Discovery
- OWASP ZAP (Web Application Scan): Import (Sample Data)
- Nikto (Server Configuration): Import (Sample Data)
- Nessus, OpenVAS/Greenbone, Burp Suite: Planned (not integrated) | Metasploit: Unsupported (lab-only, human-run)
- Correlation & Prioritization Engine: Groq (openai/gpt-oss-120b)

3. Risk Posture & Severity Distribution

Overall Posture Rating: MEDIUM

Severity Counts: Critical: 0 | High: 1 | Medium: 0 | Low: 3

4. Executive Summary

The assessment identified a high?severity SQL injection vulnerability on the application listening on 127.0.0.1:3000. Additional low?severity issues include missing security headers and server information leakage.

5. Attack Path Synthesis

1. An attacker scans and discovers the service on 127.0.0.1:3000. 2. Using the ZAP-40018 finding, the attacker sends the payload "' OR 1=1--" to exploit the SQL injection flaw and potentially retrieve or modify database data. 3. Successful injection provides unauthorized access to backend data, which can be leveraged for further compromise. 4. The lack of a Content Security Policy (ZAP-10038) and missing X-Frame-Options header (NIKTO-999101) enable client?side attacks such as XSS or clickjacking against authenticated users. 5. The exposed X?Powered?By header (NIKTO-999100) aids fingerprinting of the Express framework, assisting the attacker in tailoring subsequent exploits.

Note: Sections 4 and 5 are AI-generated from the findings before analyst review. Findings later marked 'Rejected by Analyst' in section 7 are excluded from the roadmap but may still be mentioned in this narrative.

6. Remediation Roadmap

Priority 1 | ID: ZAP-40018 | Owner: Backend

Action: Implement parameterized queries or prepared statements and enforce strict input validation to eliminate SQL injection.

Priority 4 | ID: NIKTO-999100 | Owner: Backend

Action: Remove or mask the X-Powered-By header to prevent framework fingerprinting.

7. Finding Evidence & Provenance (4)

[HIGH] Sample Data: SQL Injection (Tool: OWASP ZAP)

Target: 127.0.0.1:3000 | Confidence: 80% | Status: Probe Unreachable (Connection Refused)
Raw Source: imports\sample_zap_report.json
Trust Justification: Single source reporting; no cross-tool network confirmation.
Evidence: ' OR 1=1--

[LOW] Sample Data: Content Security Policy (CSP) Header Not Set (Tool: OWASP ZAP)

Target: 127.0.0.1:3000 | Confidence: 90% | Status: Rejected by Analyst
Raw Source: imports\sample_zap_report.json
Trust Justification: Single source reporting; no cross-tool network confirmation.
Evidence: Content Security Policy is missing from response headers.

[LOW] Sample Data: Server leaks information via X-Powered-By header: Express (Tool: Nikto (Import))

Target: 127.0.0.1:3000 | Confidence: 70% | Status: Probe Unreachable (Connection Refused)
Raw Source: imports\sample_nikto_report.json
Trust Justification: Single source reporting; no cross-tool network confirmation.
Evidence: Sample Data: Server leaks information via X-Powered-By header: Express

[LOW] Sample Data: Anti-clickjacking X-Frame-Options header is not present. (Tool: Nikto (Import))

Target: 127.0.0.1:3000 | Confidence: 70% | Status: Rejected by Analyst

Automated VAPT Assessment & Triage Report

Raw Source: imports\sample_nikto_report.json
Trust Justification: Single source reporting; no cross-tool network confirmation.
Evidence: Sample Data: Anti-clickjacking X-Frame-Options header is not present.

8. Limitations & Audit Trail

Limitations: Testing was strictly non-destructive and scoped solely to approved target ports. Safe HTTP probes evaluate endpoint reachability without verifying payload execution.

[2026-11-08 21:05:27] [BLOCKED] Scope violation blocked for target: 8.8.8.8
[2026-11-08 21:07:20] [AUTHORIZED] Plan approved by analyst for 127.0.0.1:3000
[2026-11-08 21:07:25] [OK] Nmap scan completed: 0 port(s) detected
[2026-11-08 21:07:30] [OK] Correlation completed via Groq (openai/gpt-oss-120b)
[2026-11-08 21:07:45] [VERIFIED] Benign probe on ZAP-40018 -> Probe Unreachable (Connection Refused)
[2026-11-08 21:07:47] [REJECTED] Finding ZAP-10038 rejected by analyst
[2026-11-08 21:07:48] [REJECTED] Finding ZAP-10038 rejected by analyst
[2026-11-08 21:07:53] [VERIFIED] Benign probe on NIKTO-999100 -> Probe Unreachable (Connection Refused)
[2026-11-08 21:07:56] [REJECTED] Finding NIKTO-999101 rejected by analyst